

Agent 2: Offensive Security Agent

Prepared By:

YOGA SHRI P K

GitHub Repository:

<https://github.com/YogaShri15/offensive-security-agent>

Offensive Security Agent

1. Project Overview

The Offensive Security Agent is an automated security assessment platform designed to continuously identify security risks across cloud infrastructure, application endpoints, software dependencies, and source code repositories. The system acts as a proactive security auditor by performing scheduled scans, generating actionable findings, maintaining audit logs, and notifying operators about critical vulnerabilities.

The project was developed as part of the AI/ML Hiring Challenge and implements all three challenge levels: Infrastructure Security Scanning, Multi-Domain Security Scanning, and Autonomous Continuous Monitoring.

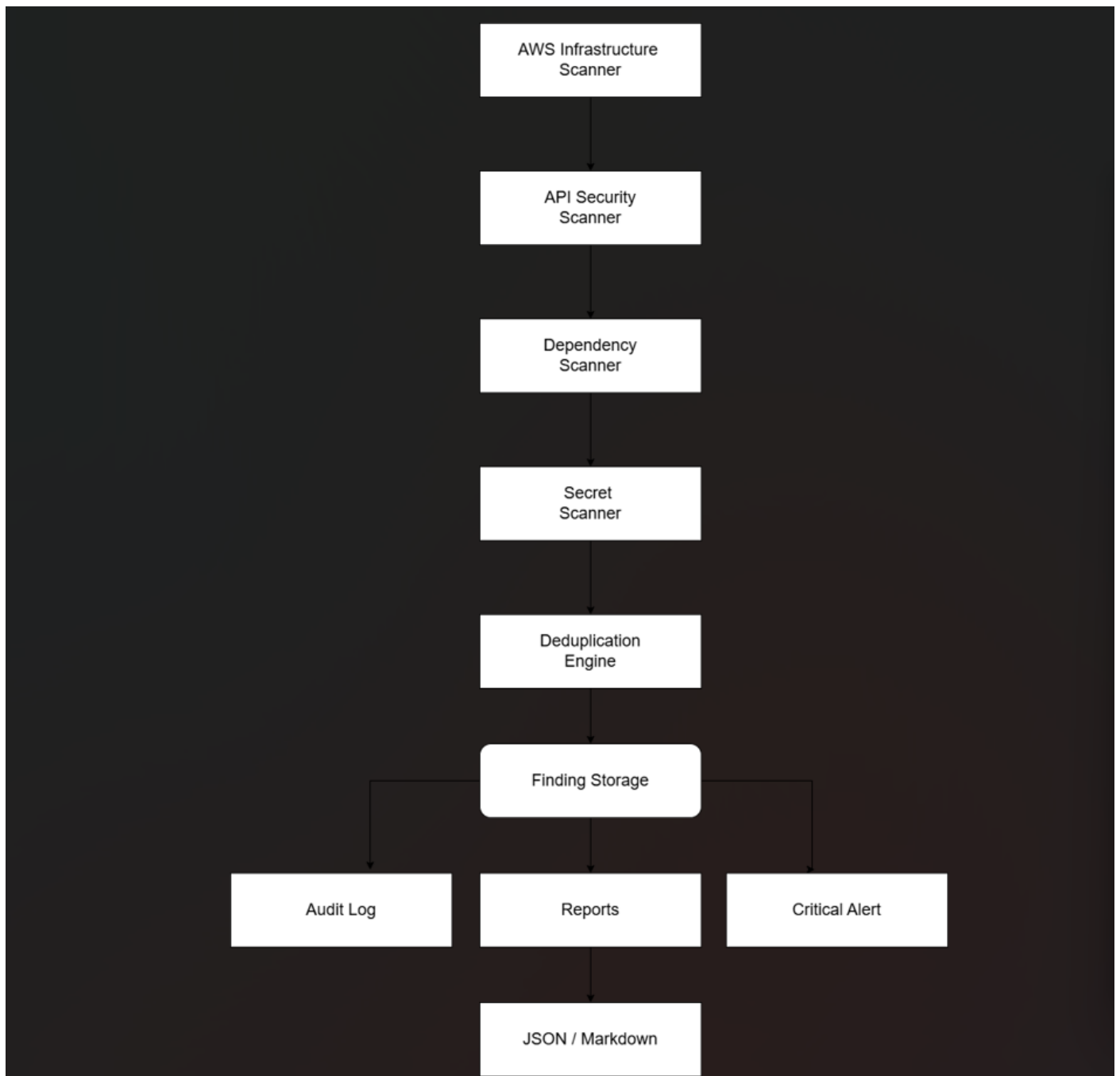
2. Architecture Overview

The solution consists of the following components:

- AWS Infrastructure Scanner
- API Security Scanner
- Dependency Vulnerability Scanner
- Secret Detection Scanner
- Deduplication Engine
- Finding Storage System
- Audit Logging Module
- Critical Alert Module
- JSON and Markdown Report Generator

All scanners generate findings that are normalized into a common format. Findings are deduplicated, stored, logged, and escalated when required.

3. Architecture Diagram



4. Level 1 – Infrastructure Security Scanning

Level 1 focuses on AWS security assessments using real AWS APIs.

Implemented Checks

- MFA Status Verification
- Administrator Access Detection
- Security Group Exposure Detection
- CloudTrail Configuration Validation
- Password Policy Assessment
- S3 Public Access Detection
- S3 Encryption Verification
- EBS Encryption Verification
- Unused Access Key Detection

Output

Each finding contains:

- Resource ARN
- Severity
- Evidence
- Business Impact
- Remediation Guidance

Reports are generated in both JSON and Markdown formats.

5. Level 2 – Multi-Domain Security Scanning

Level 2 extends scanning beyond infrastructure into application and software security.

API Security Checks

- Missing Security Headers
- Missing Content Security Policy
- Authentication Validation
- Rate Limiting Validation
- Error Disclosure Detection

Dependency Security Checks

- Vulnerable Package Detection
- CVE Identification
- CVSS Score Reporting
- Version Comparison

Secret Detection

The secret scanner detects:

- AWS Access Keys
- Hardcoded Passwords
- API Tokens
- Credential Patterns

Deduplication Engine

To prevent duplicate findings, findings are merged based on resource identifiers and evidence values.

6. Level 3 – Autonomous Continuous Monitoring

Level 3 introduces continuous security monitoring and operational automation.

Implemented Features

- Scheduled Security Scanning
- Persistent Finding Storage
- Audit Trail Generation
- Critical Alert Escalation
- Historical Finding Tracking

Finding Lifecycle

Each finding contains:

- Status
- Created Timestamp
- Last Seen Timestamp
- Resource Information
- Severity Information

Audit Logging

All scan operations are recorded including:

- Scan Start Events
- Scan Completion Events
- Finding Counts
- Operational Status

Critical Alerts

Critical findings trigger immediate notifications for rapid response.

7. Sample Findings

Infrastructure

- MFA not enabled
- Security Group open to 0.0.0.0/0
- CloudTrail not configured
- Password policy missing

Application

- Missing X-Frame-Options header
- Missing Content-Security-Policy header
- Missing authentication controls
- Missing rate limiting

Dependency

- Known vulnerable package detected
- CVE exposure identified

Secret Detection

- Hardcoded AWS credentials
- Hardcoded passwords

8. Challenges Faced

During development, several challenges were encountered:

- Handling AWS API exceptions safely
- Normalizing findings from multiple scanners
- Eliminating duplicate findings
- Designing a common finding schema
- Implementing continuous monitoring workflows
- Managing Git and GitHub deployment for project delivery

These challenges were addressed through modular architecture and standardized finding formats.

9. Future Enhancements

Potential future improvements include:

- Slack and Email alert integrations
- CVE intelligence feeds
- Automated remediation workflows
- Security posture scoring
- Dashboard and visualization layer
- Multi-cloud support (AWS, Azure, GCP)
- AI-assisted remediation recommendations

10. Conclusion

The Offensive Security Agent successfully implements all required challenge levels and demonstrates automated security assessment across infrastructure, applications, dependencies, and source code. The platform provides actionable findings, continuous monitoring capabilities, audit visibility, and critical alerting mechanisms, enabling organizations to proactively identify and remediate security risks.